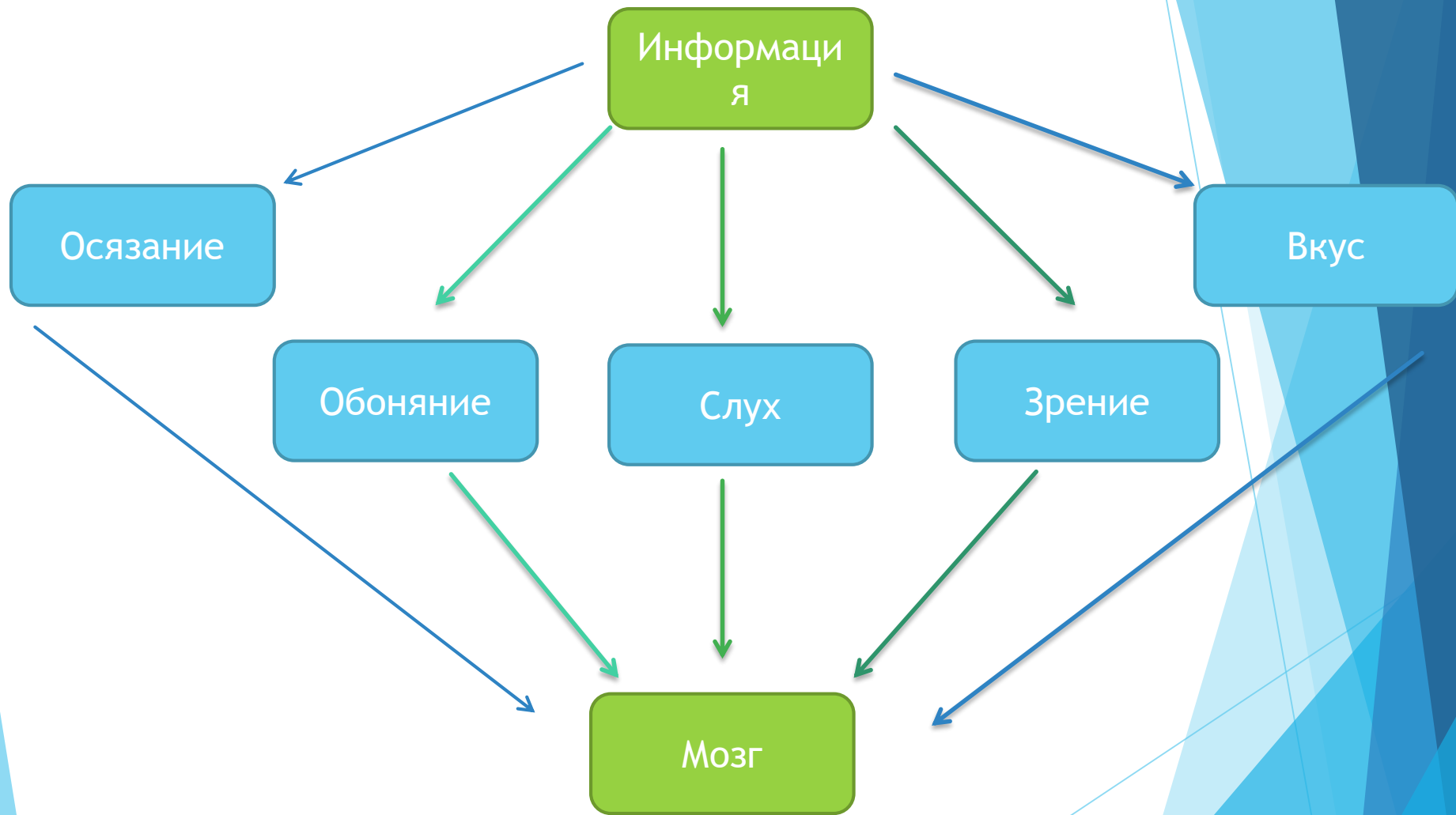


Основы информационной безопасности

Информационная безопасность

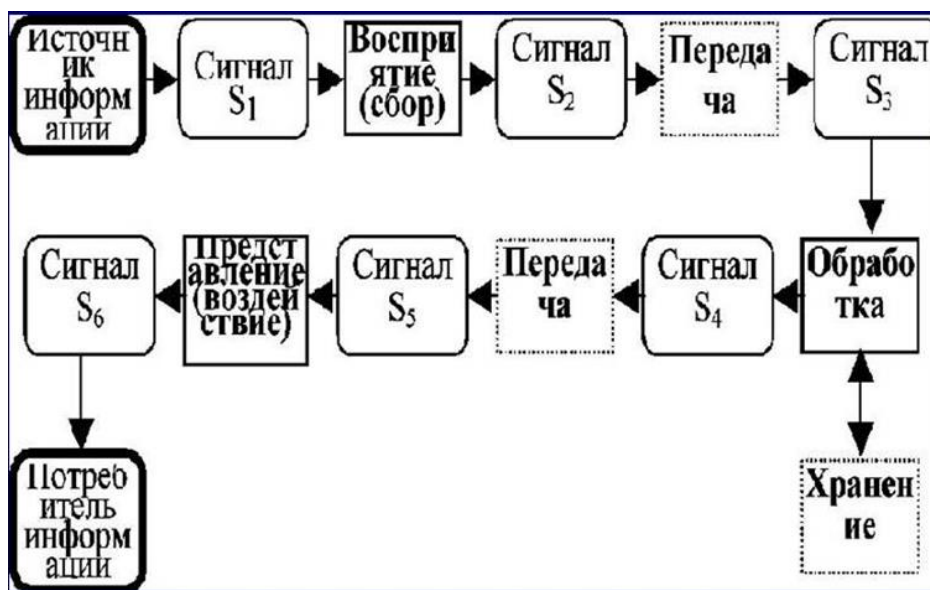
Информация - это сведения, независимы от формы их представления.

Какое существует представление информации?



Информационные процессы

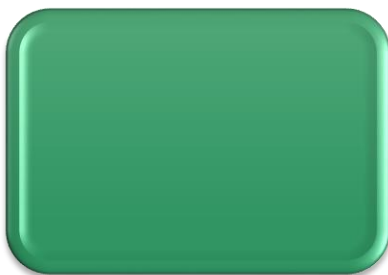
Информационные процессы процессы, связанные с поиском, хранением, передачей, обработкой и использованием информации, называются информационными процессами.



Информационные процессы



Поиск



Сбор и
хранение



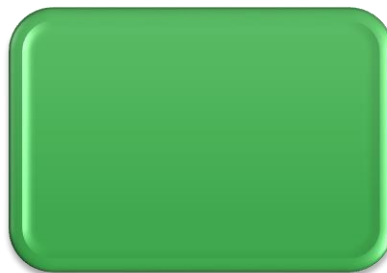
Передача



Обработка



Использование



Защита

Передача

Канал связи - совокупность технических устройств, обеспечивающих передачу сигнала от источника к получателю.

Кодирующее устройство - устройство, предназначенное для преобразования исходного сообщения источника к виду, удобному для передачи.

Декодирующее устройство - устройство для преобразования кодированного сообщения в исходное.

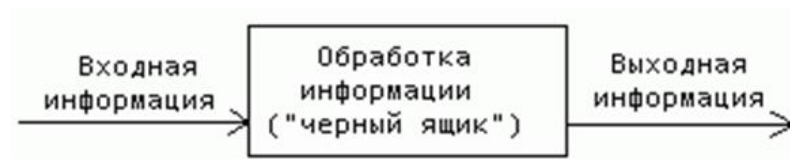


Обработка

Примеры обработки информации

Примеры	Входная информация	Выходная информация	Правило

"Черный ящик" - это система, в которой внешнему наблюдателю доступны лишь информация на входе и на выходе этой системы, а строение и внутренние процессы неизвестны.



Защита

Защитой информации называется предотвращение:

- доступа к информации лицам, не имеющим соответствующего разрешения (несанкционированный, нелегальный доступ);
- непредумышленного или недозволенного использования, изменения или разрушения информации.



Информационная безопасность

Информация - это сведения, независимы от формы их представления.

Информационные технологии - процессы, методы поиска, сбора, хранения, обработки, предоставления, распространения информации и способы осуществления таких процессов и методов.

Информационная безопасность - состояние защищенности данных. (Отвечает на вопрос какая?)

А защита информации это что?

Защита информации - комплекс мер направленных на повышение уровня информационной безопасности.

Информационная безопасность прямо пропорциональна защите информации.

История информационной безопасности

I этап (до 1816 года)

Характеризуется использованием естественно возникших средств информационных коммуникаций. В этот период основная задача информационной безопасности заключалась в защите сведений о событиях, фактах, имуществе и др. данных

II этап (начиная с 1816 года)

Связан с началом использования искусственно создаваемых технических средств электро-радио связи. Для обеспечения скрытности необходимо было применение помехоустойчивого кодирования и декодирования сигнала.

III этап (с 1935 года)

Появление радиолокационных и гидроакустических средств. Основным способом обеспечения информационной безопасности было сочетание организационных и технических мер, противостоящих воздействию радиоэлектронных помех.

IV этап (начиная с 1946 года)

Изобретение и внедрение в практическую деятельность ЭВМ. Задачи информационной безопасности решались способом ограничения физического доступа к оборудованию.

V этап (начиная с 1965 года)

Создание и развитие локальных сетей. Задачи информационной безопасности решались методами физической защиты оборудования объединенного в локальную сеть путем администрирования и управления доступом к сетевым ресурсам.

VI этап (с 1973)

Использование сверхмобильных коммуникационных устройств. Угрозы информационной безопасности стали гораздо серьезнее, потребовалась разработка новых критериев безопасности. Образовались сообщества людей-хакеров, цель которых нанесение ущерба информационной безопасности.

Этап VII (начиная с 1985)

Создание и развитие информационно-коммуникационных сетей с использованием космических средств обеспечения. Этот этап развития связан с широким использованием сверхмобильных коммуникационных устройств. Для решения задач ИБ необходимо создание макросистем ИБ человечества.

ИНФОРМАЦИОННОЕ ОБЩЕСТВО

Информационное общество - это такая стадия развития общества, когда использование информационно-коммуникационных технологий (ИКТ) оказывает существенное влияние на основные социальные институты и сферы жизни:

- ▶ экономика и деловая сфера,
- ▶ государственное управление,
- ▶ образование,
- ▶ социальное обслуживание и медицина,
- ▶ культура и искусство.

ПРИМЕРЫ ПРИМЕНЕНИЯ В РАЗЛИЧНЫХ СФЕРАХ:

- ▶ Экономическая: информация используется в качестве ресурса, услуг, товара, источника добавленной стоимости и занятости, получает развитие электронный бизнес.
- ▶ Политическая: свобода информации, ведущая к развитию электронной демократии, электронного государства, электронного правительства.
- ▶ Электронное государство — это способ повышения эффективности деятельности государства, основанный на использовании информационных систем.
- ▶ Социальная: информация выступает в качестве важного стимулятора изменения качества жизни.
- ▶ Культурная: признание культурной ценности информации

ПОЛОЖИТЕЛЬНЫЕ ЧЕРТЫ ИНФОРМАЦИОННОГО ОБЩЕСТВА:

- Решена проблема информационного кризиса
- Обеспечен приоритет информации по сравнению с другими ресурсами
- Главной формой развития станет информационная экономика
- Использование знаний с помощью новейшей информационной техники и технологии
- Информационная технология приобретет глобальный характер, который охватывает все сферы социальной деятельности человека
- Формируется информационное единство всей человеческой цивилизации
- Реализован свободный доступ каждого человека к информационным ресурсам всей цивилизации
- Реализованы гуманистические принципы управления обществом и воздействия на окружающую среду

ОТРИЦАТЕЛЬНЫЕ ЧЕРТЫ ИНФОРМАЦИОННОГО ОБЩЕСТВА:

- ▶ Большое влияние на общество средств массовой информации
- ▶ Информационные технологии могут разрушить частную жизнь людей и организаций
- ▶ Существует проблема отбора качественной и достоверной информации
- ▶ Многим людям трудно адаптироваться к среде информационного общества США, Япония, Англия, Германия, страны Западной Европы)

ИНФОРМАТИЗАЦИЯ ОБЩЕСТВА

Информатизация общества - это организованный социально-экономический и научно-технический процесс создания оптимальных условий для удовлетворения информационных потребностей и реализации прав граждан, органов государственной власти, органов местного самоуправления, организаций, общественных объединений на основе формирования и использования информационных ресурсов.

Условия информатизации

Политические

создание эффективной системы обеспечения прав граждан и социальных институтов на свободное получение и распространения информации как важнейшего условия соблюдения прав человека.

Социальным (в смысле общественным) условиям успешного развития информатизации

достаточно высокий уровень благосостояния населения

Экономические

Конкуренция

Технологические

Возможности хранения и обновления информации

ОСНОВНЫЕ ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

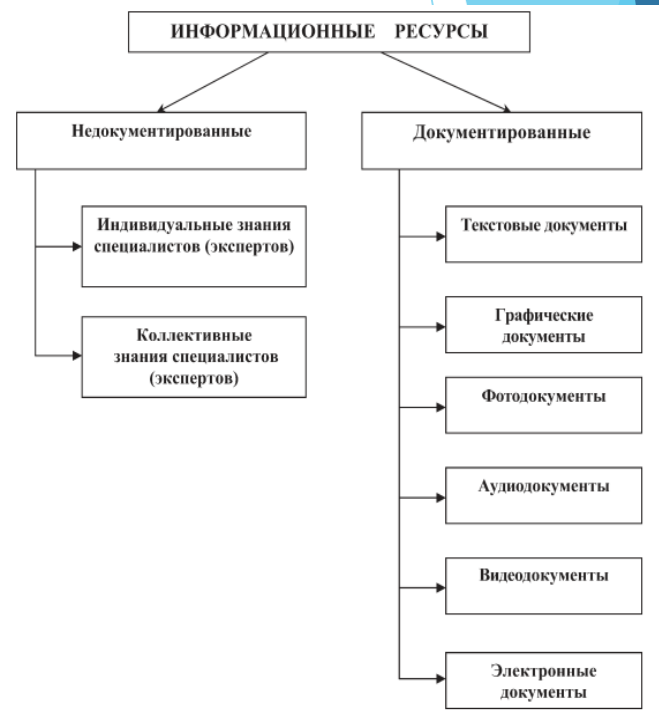
- ▶ Информация
- ▶ Информационные ресурсы
- ▶ Информационные системы
- ▶ Информационные технологии
- ▶ Информационные процессы
- ▶ Угрозы информационной безопасности



ОСНОВНЫЕ ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

► Информационные ресурсы -

документы и массивы документов в информационных системах (библиотеках, архивах, фондах, банках данных, депозитариях, музейных хранилищах и т. п.)



ОСНОВНЫЕ ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

Информационная система — системы, предназначенная для хранения, поиска и обработки информации, и соответствующие организационные ресурсы (человеческие, технические, финансовые и т. д.), которые обеспечивают и распространяют информацию

Система	Элементы системы	Главная цель системы
Информационная система	Компьютеры, компьютерные сети, люди, информационное и программное обеспечение	Производство профессиональной информации

ОСНОВНЫЕ ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

- **Автоматизированная система** - система, состоящая из персонала и комплекса средств автоматизации его деятельности, реализующая информационную технологию выполнения установленных функций. ГОСТ 34.003-90
- Под безопасностью автоматизированной информационной системы организации (учреждения) понимается ее защищенность от случайного или преднамеренного вмешательства в нормальный процесс функционирования, а также от попыток хищения, модификации или разрушения ее компонентов. Безопасность системы достигается обеспечением конфиденциальности обрабатываемой ею информации, а также целостности и доступности компонентов и ресурсов системы.

Безопасность

Безопасность - состояние защищенности жизненно важных интересов личности, общества и государства от внутренних и внешних угроз



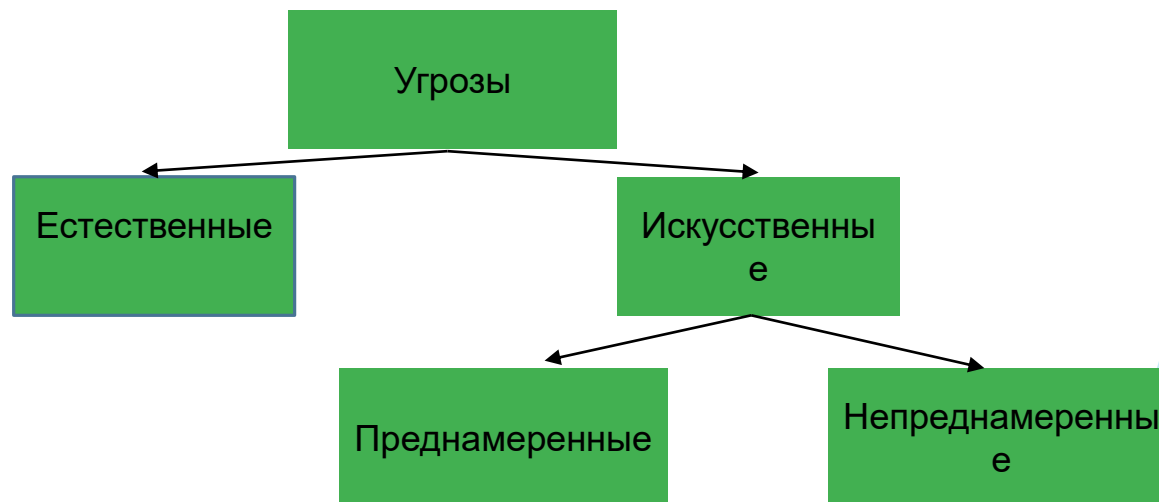
Угроза

1. Угроза - совокупность условий и факторов, создающих опасность жизненно важным интересам личности, общества и государства
2. Угроза - потенциальный источник возникновения ущерба.
3. Угроза - потенциальная причина инцидента, который может нанести ущерб системе или организации.



УГРОЗЫ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

УГРОЗА БЕЗОПАСНОСТИ ИНФОРМАЦИИ - совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.



УГРОЗЫ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

ПРИМЕРЫ

Атака — попытка реализации угрозы.

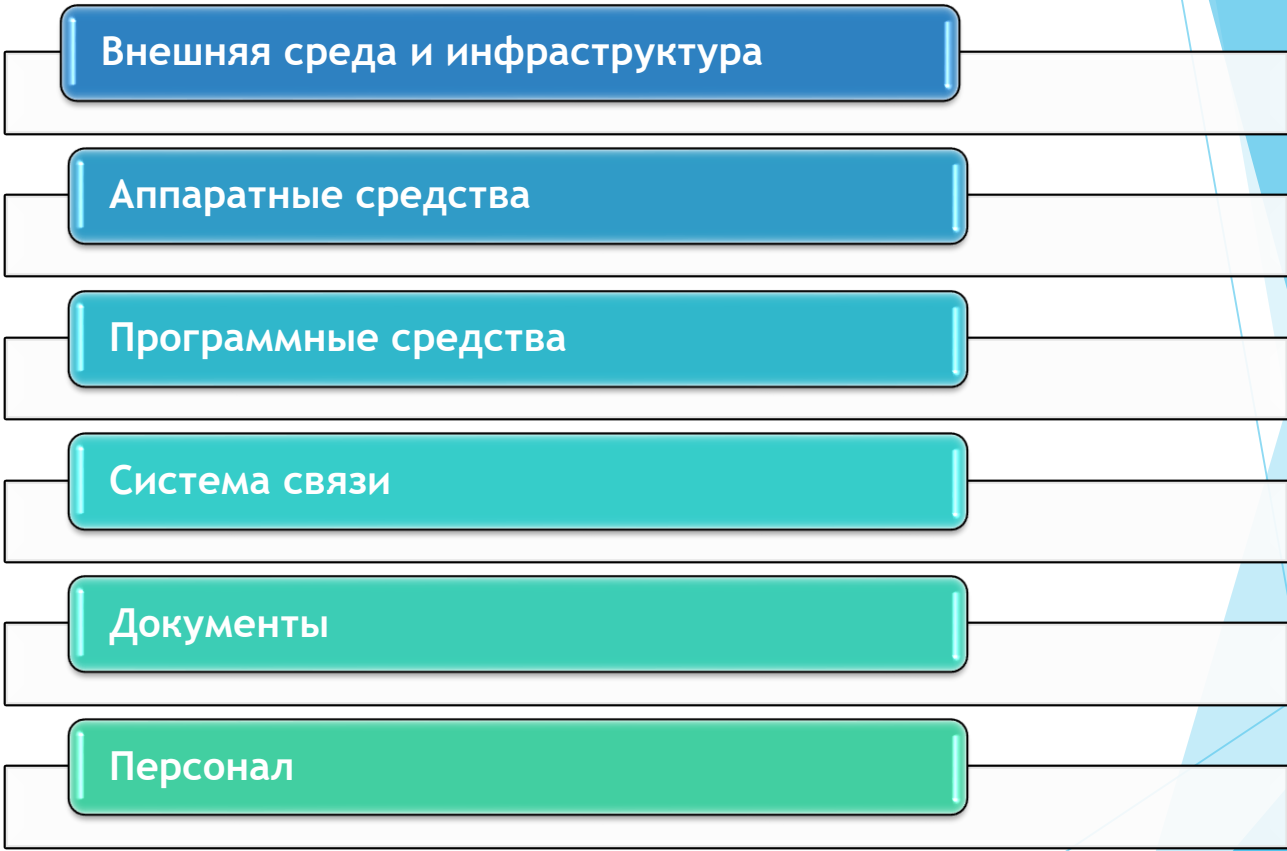
Нарушение — реализация угрозы.

Промежуток времени от момента, когда появляется возможность использовать слабое место, и до момента, когда пробел ликвидируется, называется **окном опасности**, ассоциированным с данным уязвимым местом. Пока существует окно опасности, возможны успешные атаки на ИС.



В компьютерной безопасности термин «**уязвимость**» (англ. vulnerability) используется для обозначения недостатка в системе, используя который внешний злоумышленник, может намеренно нарушить её целостность и вызвать неправильную работу.





Внешняя среда и инфраструктура

Аппаратные средства

Программные средства

Система связи

Документы

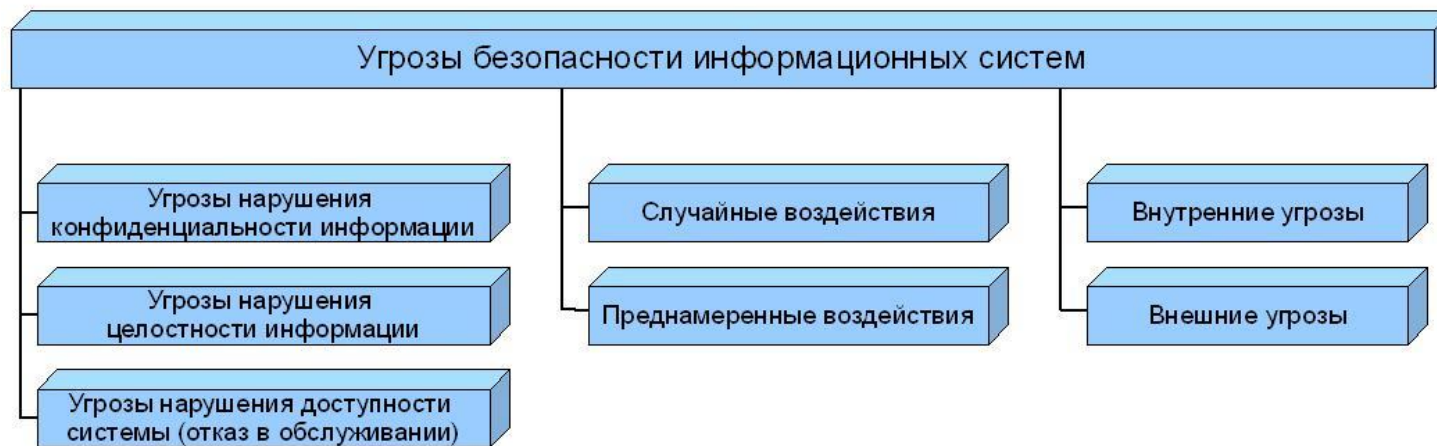
Персонал

Процедурные

Обычные уязвимости
обработки бизнес-приложений

Общеприменимые уязвимости

Классификация угроз информационной безопасности



1. По аспекту ИБ: угрозы конфиденциальности, угрозы целостности, угрозы доступности. Дополнительно можно выделить угрозы аутентичности и апеллируемости.

2. По компонентам АИС, на которые нацелена угроза: данные, программное обеспечение, аппаратное обеспечение, поддерживающая инфраструктура).

3. По расположению источника угроз: внутри или вне рассматриваемой АИС. Угрозы со стороны инсайдеров являются наиболее опасными.



Естественные угрозы — это угрозы, вызванные воздействиями на АИС и ее элементы объективных физических процессов или стихийных природных явлений, независящих от человека.

4. По природе возникновения:

естественные (объективные) и
искусственные (субъективные).

Искусственные угрозы — угрозы, вызванные деятельностью человека. Среди них, исходя из мотивации действий, можно выделить непреднамеренные (неумышленные, случайные) угрозы, вызванные ошибками в проектировании АИС и ее элементов, ошибками в программном обеспечении, ошибками в действиях персонала и т.п., и преднамеренные (умышленные) угрозы, связанные с целенаправленными устремлениями злоумышленников.

5. По непосредственному источнику угроз.

5.1. *Угрозы, непосредственным источником которых является природная среда* (стихийные бедствия, магнитные бури, радиоактивное излучение и т.п.).

5.2. *Угрозы, источником которых является человек:*

5.3. *Угрозы, непосредственным источником которых являются санкционированные программно-аппаратные средства:*

5.4. *Угрозы, непосредственным источником которых являются несанкционированные программно-аппаратные средства:*



6. По положению источника угроз.

6.1. Угрозы, источник которых расположен вне контролируемой зоны территории (помещения), на которой находится АС:

6.2. Угрозы, источник которых расположен в пределах контролируемой зоны территории (помещения), на которой находится АС:

6.3. Угрозы, источник которых имеет доступ к периферийным устройства АС(терминалам).

6.4. Угрозы, источник которых расположен в АС:

7. По степени зависимости от активности АС.

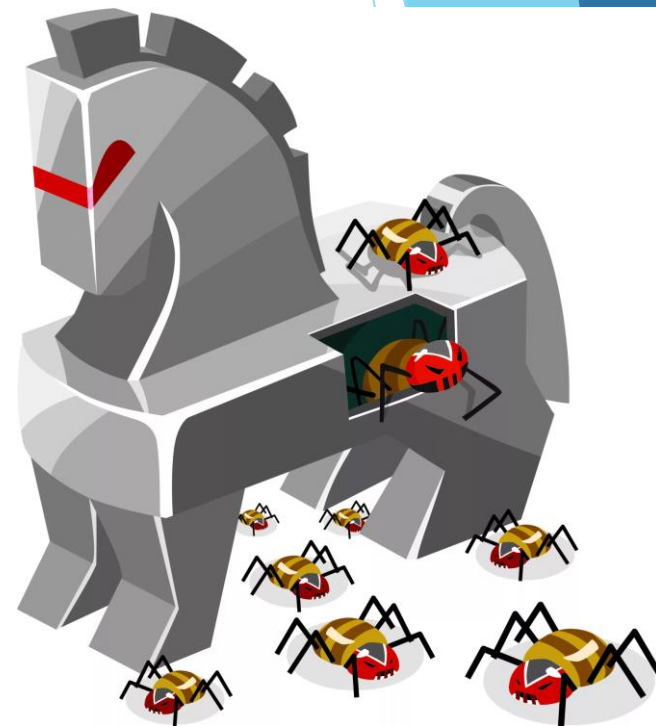
7.1. Угрозы, которые могут проявляться независимо от активности АС:

7.2. Угрозы, которые могут проявляться только в процессе автоматизированной обработки данных

8. По степени воздействия на АС.

8.1. Пассивные угрозы, которые при реализации ничего не меняют в структуре и содержании АС (угроза копирования секретных данных).

8.2. Активные угрозы, которые при воздействии вносят изменения в структуру и содержание АС:



9. По этапам доступа пользователей или программ к ресурсам АС.

9.1. Угрозы, которые могут проявляться на этапе доступа к ресурсам АС(например, угрозы несанкционированного доступа в АС).

9.2. Угрозы, которые могут проявляться после разрешения доступа к ресурсам АС(например, угрозы несанкционированного или некорректного использования ресурсов АС).

10. По способу доступа к ресурсам АС.

10.1. Угрозы, направленные на использование прямого стандартного пути доступа к ресурсам АС:

10.2. Угрозы, направленные на использование скрытого нестандартного пути доступа к ресурсам АС:

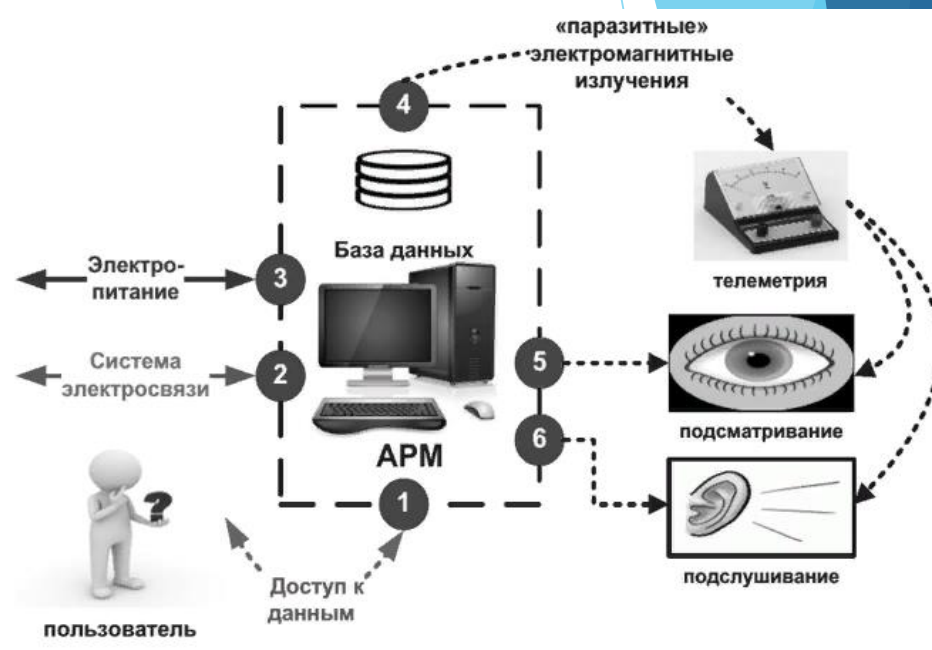
11. По текущему месту расположения информации, хранимой и обрабатываемой в АС.

11.1. Угрозы доступа к информации на внешних запоминающих устройства

11.2. Угрозы доступа к информации в оперативной памяти:

11.3. Угрозы доступа к информации, циркулирующей в линиях связи:

11.4. Угрозы доступа к информации, отображаемой на терминале или печатаемой на принтере



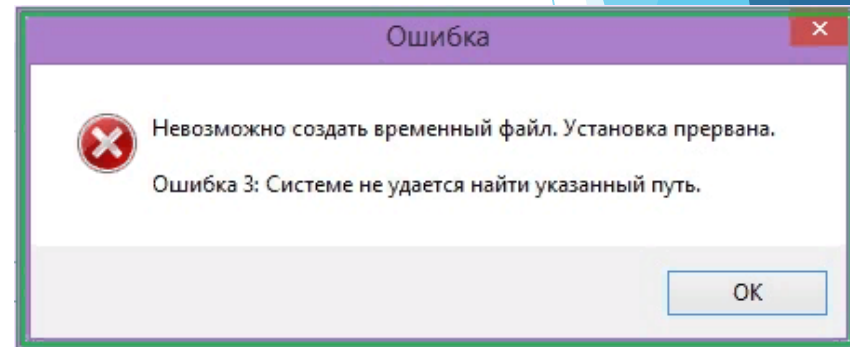


Угроза доступности (отказа служб) возникает всякий раз, когда в результате преднамеренных действий, предпринимаемых другим пользователем или злоумышленником, блокируется доступ к некоторому ресурсу вычислительной системы. Реально блокирование может быть постоянным - запрашиваемый ресурс никогда не будет получен, или оно может вызывать только задержку запрашиваемого ресурса, достаточно долгую для того, чтобы он стал бесполезным. В этих случаях говорят, что ресурс исчерпан

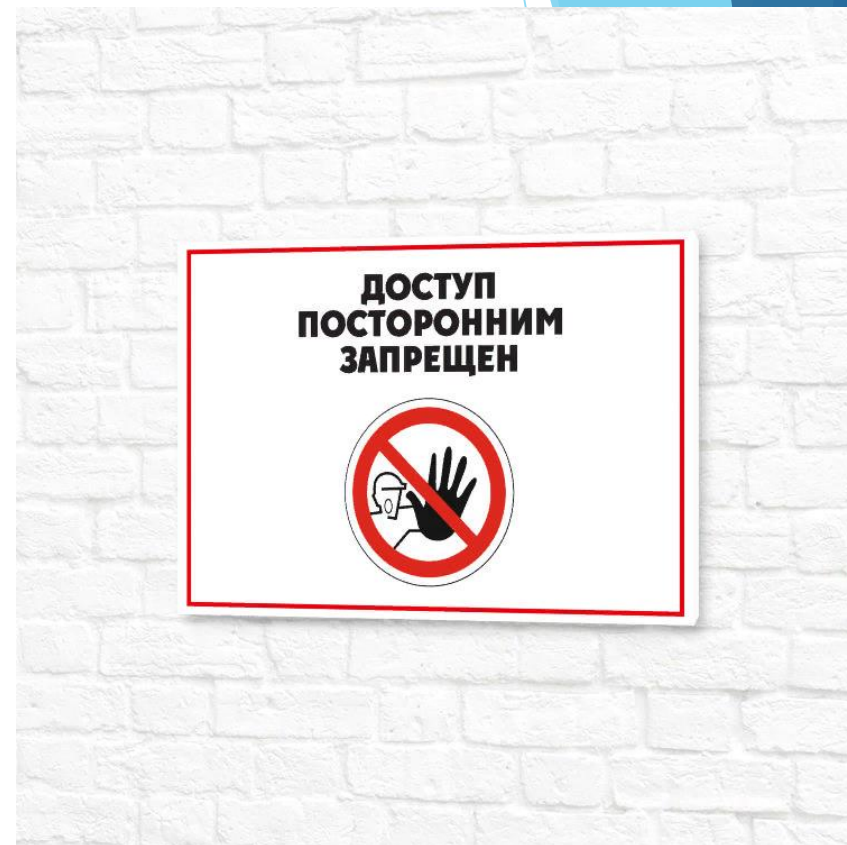


Угроза нарушения целостности включает в себя любое умышленное изменение информации, хранящейся в вычислительной системе или передаваемой из одной системы в другую, в том числе и несанкционированное изменение информации при случайных ошибках программного или аппаратного обеспечения.

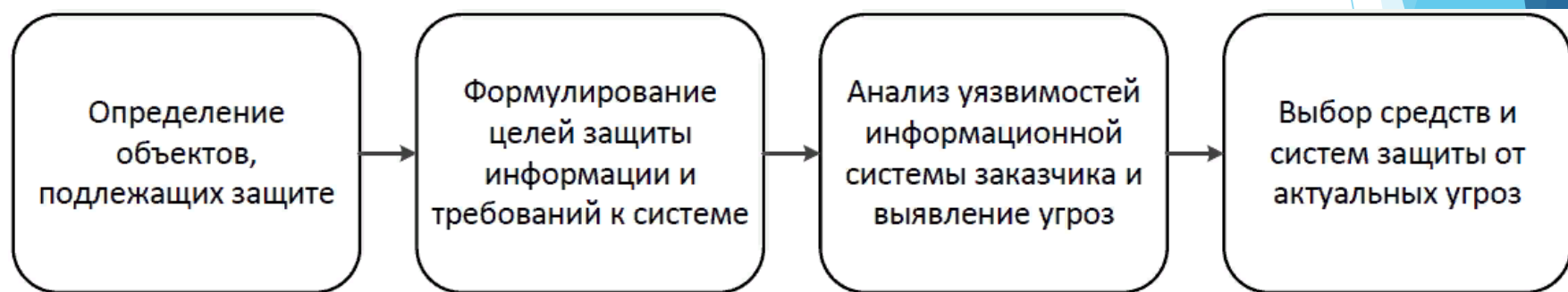
Санкционированными изменениями являются те, которые сделаны уполномоченными лицами с обоснованной целью (например, периодическая запланированная коррекция некоторой базы данных).



Угроза нарушения конфиденциальности заключается в том, что информация становится известной тому, кто не располагает полномочиями доступа к ней. Иногда, в связи с угрозой нарушения конфиденциальности, используется термин "утечка".



***Защита информационной системы
считается преодоленной, если в ходе ее
исследования определены все уязвимости
системы.***



Угроза раскрытия параметров АС

- ***Информационные угрозы***
- ***Программно-математические угрозы***
- ***Физические угрозы***
- ***Организационные угрозы***

Предпосылки появления угроз.

Существует две возможные разновидности предпосылок: **объективные** (количественная или качественная недостаточность элементов системы) и **субъективные** (деятельность разведорганов иностранных государств, промышленный шпионаж, деятельность уголовных элементов, действия недобросовестных сотрудников системы).



Перечисленные разновидности предпосылок интерпретируются следующим образом:

количественная недостаточность – физическая нехватка одного или нескольких элементов системы, вызывающая нарушения технологического процесса обработки данных и/или перегрузку имеющихся элементов;

качественная недостаточность – несовершенство конструкции (организации) элементов системы, в силу чего могут появляться возможности случайного или преднамеренного негативного воздействия на обрабатываемую или хранимую информацию;

деятельность разведорганов иностранных государств – специально организуемая деятельность государственных органов, профессионально ориентированных на добывание необходимой информации всеми доступными способами и средствами.

Разведка

```
graph TD; A[Разведка] --> B[Агентурная]; A --> C[Техническая]; C --> D[Радиотехническая разведка]; C --> E[Радиоразведка]; C --> F[Космическая разведка];
```

Агентурная

(несанкционированная деятельность профессиональных разведчиков, завербованных агентов и так называемых «доброжелателей», «инициативников»)

Техническая

Радиоразведка

(перехват радиоэлектронными средствами информации, циркулирующей в телекоммуникационных каналах)

Радиотехническая разведка

(регистрацию спецсредствами электромагнитных излучений технических систем)

Космическая разведка

(использование космических кораблей и искусственных спутников Земли для наблюдения за территорией, ее фотографирования, регистрации радиосигналов и получения полезной информации любыми другими доступными способами);

Разведка

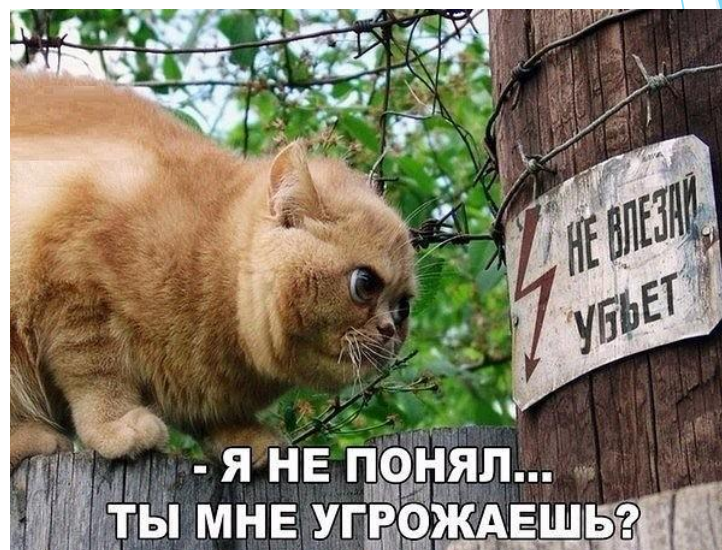
промышленный шпионаж — негласная деятельность организации (ее представителей) по добыванию информации, специально охраняемой от несанкционированной ее утечки или хищения, с целью создания для себя благоприятных условий и получения максимальных выгод (недобросовестная конкуренция);

злоумышленные действия уголовных элементов — хищение информации или компьютерных программ в целях наживы;

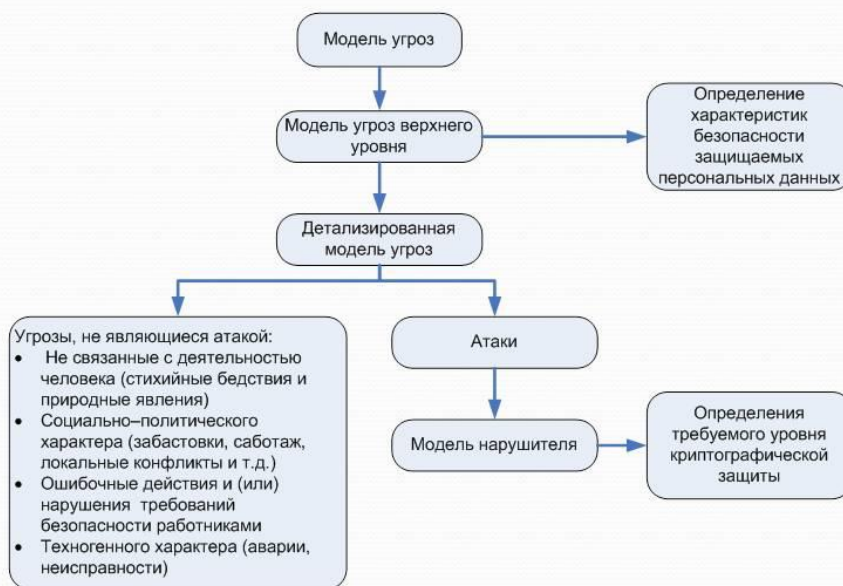
действия недобросовестных сотрудников — хищение (копирование) или уничтожение информационных массивов и/или программ по эгоистическим или корыстным мотивам, а также в результате несоблюдения установленного порядка работы с информацией.

Модель угроз

Говоря об угрозах часто используется понятие «**модели угроз**», которая, согласно СТО БР ИББС 1.0-2006, «включает описание **источников угроз, уязвимостей, используемых угрозами, методов и объектов нападения, типов возможной потери, масштабов потенциального ущерба**».



Модель угроз



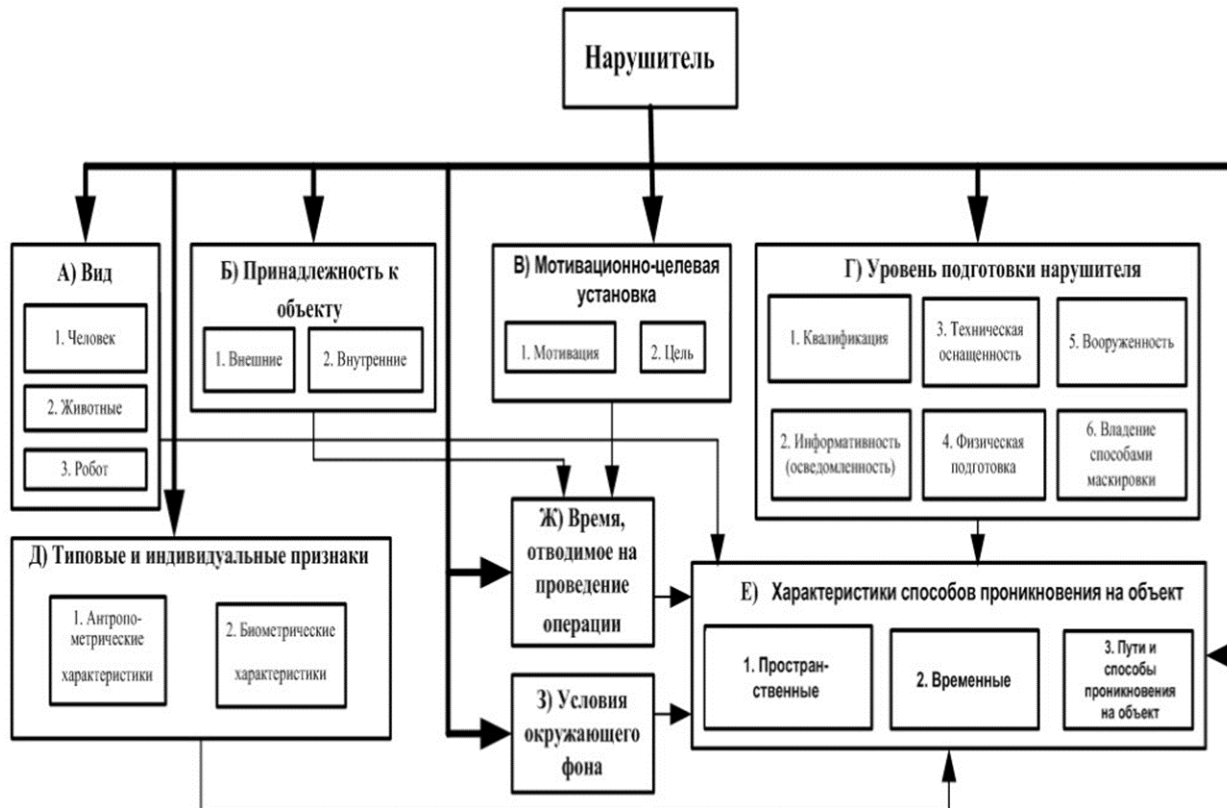
Модель нарушителя

Источник угроз - субъект, материальный объект или физическое явление, создающее угрозу безопасности информации.

Для источников угроз – людей – разрабатывается **модель нарушителя**. В модели нарушителя конкретизируются субъекты, их средства, знания и опыт, с помощью которых они могут реализовать угрозы и нанести ущерб объектам, а также мотивации их действий.



Модель нарушителя



Риск

Риск - неопределенность, предполагающая возможность потерь (ущерба)

На практике можно встретить следующие виды рисков:

- стратегический риск,
- юридический риск,
- операционный риск,
- репутационный риск,
- рыночный риск,
- кредитный риск,
- инвестиционный риск,
- политический риск,
- проектный риск,
- ИТ - риск,
- риск информационной безопасности,
- и другие.



Система обеспечения безопасности того или иного объекта решает следующие задачи:

1. Своевременное выявление и прогнозирование внешних и внутренних угроз.
2. Осуществление комплекса оперативных и долговременных мер по предупреждению и нейтрализации внутренних и внешних угроз.
3. Создание и поддержание в готовности сил и средств для обеспечения безопасности.
4. Управление силами и средствами обеспечения безопасности в нормальных (повседневных) условиях и при возникновении чрезвычайных ситуаций.
5. Осуществление системы мер по нормальному функционированию объектов безопасности после возникновения чрезвычайных ситуаций.
6. Участие в мероприятиях по обеспечению безопасности за пределами своего объекта в соответствии с договоренностями (соглашениями) внутри корпорации или объединения фирм (предприятий).